SENG 34213 / FINAL DELIVERABLES / FOOD ORDERING SYSTEM (FOSS)

OWASP Top 10 Security Evidence — FOSS

SENG 34213 section 8.1 A01–A10 control-by-control security review for the Food Ordering System (FOSS). Distinguishes passing unit, integration, and E2E security assertions from broader service and deployment controls.

DOCUMENT STATUS: PROVISIONAL REVIEW; APPLICATION CONTROLS EVIDENCED

1 Scope and evidence snapshot

Reviewed CI	GitHub Actions Workflow run #41833172660 & Local Test Suites
Tested revision	fix/issue-116-fds-stay-expiry | b4b19df (Refs #116, #115)
Evidence branch	fix/issue-116-fds-stay-expiry (Issues #111, #115, #116)
Preceding milestones	CIT-04 / PR #105 (SSE); CIT-05 / PR #107 (Testing & Security); PR #115 (Live Orders); Issue #116 (FDS Expiry)
Backend scope	NestJS 12 backend: 9 controllers, 36 REST endpoints, TypeORM, RabbitMQ consumer/publisher, SSE
Frontend scope	Next.js 16 / React 19 SPA: QR activation, menu, cart caps (20), 10-min cancellation, dual-mode isolation
Database isolation	PostgreSQL via Neon; HealthService evaluates pg_settings to block execution against production/dev branches

2 OWASP Top 10 Control-by-Control Evaluation

A01 Broken Access Control	**PARTIALLY EVIDENCED**
Evidence / Controls	Guest requests require signed Bearer JWT. RoomOwnershipGuard validates roomNumber and bookingId on all guest endpoints. Cross-room IDOR attempts return 403 Forbidden. Immediate session revocation upon FDS checkout event. Authoritative FDS stayEnd timestamp caps QR slip validity and invalidates expired guest stays (Issue #116).
Source / Test	`backend/src/common/auth/room-ownership.guard.ts; backend/src/modules/guest-sessions/services/guest-sessions.service.ts; backend/test/room-scoped-auth.e2e-spec.ts`
Follow-up Action	Coordinate with API Gateway team to enforce IP-based rate limiting on /foss/guest-sessions/qr and execute multi-tenant penetration tests.
A02 Cryptographic Failures	**PARTIALLY EVIDENCED**
Evidence / Controls	QR tokens signed using HMAC-SHA256 (QR_HMAC_SECRET). Session JWTs passed exclusively via Authorization: Bearer header. Fetch-based SSE eliminates token leakage in EventSource URLs. Neon database enforces TLS 1.3.
Source / Test	`backend/src/modules/guest-sessions/services/qr-activation.service.ts; frontend/tests/realtime-client-security.test.ts`
Follow-up Action	Verify production API Gateway TLS termination cipher suites and confirm vault key rotation schedule.
A03 Injection	**PARTIALLY EVIDENCED**
Evidence / Controls	TypeORM repositories use parameterized SQL queries exclusively (zero raw string interpolation). NestJS ValidationPipe with whitelist: true strips undeclared fields. Free-text inputs capped: allergy notes <= 300 chars, complaint/service descriptions <= 500 chars.
Source / Test	`backend/src/modules/food-orders/dto/create-order.dto.ts; backend/test/api-validation-and-errors.e2e-spec.ts; frontend/tests/pricing-and-quantity.test.ts`
Follow-up Action	Run automated OWASP ZAP baseline API scan against containerized backend routes.
A04 Insecure Design	**PARTIALLY EVIDENCED**
Evidence / Controls	High-entropy idempotency keys prevent duplicate orders and double-billing. 10-minute order cancellation window (GA-07) strictly enforced on backend. Server recalculates prices from authoritative catalog. Cart line-item quantity capped at 20.
Source / Test	`backend/src/modules/food-orders/food-orders.service.ts; backend/test/food-orders.e2e-spec.ts; frontend/tests/cart.test.ts`
Follow-up Action	Obtain formal architectural review for transactional outbox (CR-outbox-foss.md proposed).
A05 Security Misconfiguration	**PARTIALLY EVIDENCED**
Evidence / Controls	Strict environment validation via class-validator at bootstrap (env.validation.ts). HealthService evaluates Neon branch identity to prevent tests mutating development/production DBs. Exception filter prevents stack trace disclosure.
Source / Test	`backend/src/config/env.validation.ts; backend/src/health/health.service.ts; backend/src/common/filters/http-exception.filter.ts`
Follow-up Action	Validate gateway security headers (CSP, HSTS) and non-root Docker container deployment.
A06 Vulnerable and Outdated Components	**PARTIALLY EVIDENCED**
Evidence / Controls	Automated linting via Oxlint (240 backend files) and ESLint 9 (frontend) passing with 0 errors/warnings. Strict package-lock.json version pinning. Dependency audit reviewed and safe cleanup merged in PR #109.
Source / Test	`backend/package.json; frontend/package.json; GitHub Actions Workflow #41833172660`
Follow-up Action	Configure automated Dependabot security alerts and document accepted residual risks.

A07 Identification and Authentication Failures	**PARTIALLY EVIDENCED**
Evidence / Controls	QR slip activation requires valid booking reference, room number, and temporary access code. Session tokens have 24-hour TTL (SESSION_TTL_HOURS=24). Immediate session revocation upon reception checkout event.
Source / Test	`backend/src/modules/guest-sessions/guest-sessions.service.ts; backend/test/fds-checkout-session-revocation.e2e-spec.ts`
Follow-up Action	Enforce gateway-level brute force protection and progressive delay on QR redemption.

A08 Software and Data Integrity Failures	**PARTIALLY EVIDENCED**
Evidence / Controls	RabbitMQ inter-service messages require signed event envelopes with HMAC-SHA256 signatures. In-memory/Redis deduplication discards duplicate events. Dead-letter queue (forever.hotel.dlq) captures unparseable messages. synchronize: false enforced.
Source / Test	`backend/src/integrations/contracts/signed-event-envelope.ts; backend/src/messaging/rabbitmq-consumer.service.ts`
Follow-up Action	Enforce broker TLS and dedicated vhost isolation in production RabbitMQ deployment.

A09 Security Logging and Monitoring Failures	**PARTIALLY EVIDENCED**
Evidence / Controls	Distributed tracing via CorrelationMiddleware attaches X-Correlation-ID. LogSanitizerUtil masks passwords, Bearer tokens, and guest PII to [REDACTED]. Structured NestJS logging with module context tags.
Source / Test	`backend/src/common/middleware/correlation.middleware.ts; backend/src/common/logging/log-sanitizer.util.ts`
Follow-up Action	Integrate container stdout streams with central hotel infrastructure log aggregator (Elasticsearch/Loki).

A10 Server-Side Request Forgery (SSRF)	**PARTIALLY EVIDENCED**
Evidence / Controls	All outbound HTTP calls to external hotel subsystems (FDS, KMS, WKMS, MAD) use strictly preconfigured, validated environment base URLs. No user-supplied URLs, webhooks, or IP addresses are accepted or fetched.
Source / Test	`backend/src/integrations/internal-services/booking/adapters/real-booking.adapter.ts; backend/src/integrations/internal-services/kms/adapters/real-kms.adapter.ts`
Follow-up Action	Enforce Kubernetes/Docker egress network policies preventing container access to cloud metadata endpoints (169.254.169.254).

3 Cross-Service Security Boundaries & Dependency Governance

• **API Gateway Rewrite:** External browser traffic reaches FOSS via /foss/* rewritten to port 4300. Staff authentication headers do not automatically grant FOSS guest session authority.
• **Guest Auth Boundary:** FOSS issues and validates its own guest Bearer JWT tokens bound to active stays verified via FDS.
• **RabbitMQ Isolation:** Inter-service messaging utilizes the shared exchange forever.hotel.events with HMAC-SHA256 signature verification. Poisoned messages route to forever.hotel.dlq.
• **Database Safety:** TypeORM runs with synchronize: false. FOSS stores guest orders in foss_orders and never writes to KMS, FDS, or WKMS canonical tables directly.